

CO4-AT2

NAME: MUKESH EASHWAR M

REG NO : 192572125

SUB : ETHICAL HACKING

CODE : ITA1407

1. TJX Companies Wireless Network Breach (2005–2007)

Vulnerability Assessment

The TJX breach demonstrated the dangers of using outdated wireless security mechanisms and inadequate network controls. The use of **WEP** provided insufficient protection because WEP can be compromised much more easily than modern encryption standards.

Key Vulnerabilities

Area	Vulnerability	Risk
Wireless encryption	WEP used during transition to WPA	High
Authentication	Weak wireless authentication	High
Network segmentation	Wireless network insufficiently isolated	Critical
Monitoring	Inadequate wireless/network monitoring	High
Payment data	Sensitive card data insufficiently protected	Critical

Recommendations

1. Replace WEP with **WPA2-AES or WPA3**.
2. Use **802.1X/RADIUS enterprise authentication** instead of shared passwords.
3. Separate wireless clients from POS systems using VLANs and firewalls.
4. Deploy Wireless Intrusion Detection/Prevention Systems (WIDS/WIPS).
5. Encrypt payment information both **in transit and at rest**.
6. Apply **PCI DSS** requirements for cardholder-data environments.
7. Regularly perform vulnerability scans and penetration tests.
8. Maintain centralized security logging and alerting.

Useful Linux Commands

ip addr

ip route

```
nmcli device wifi list
```

```
iw dev
```

For authorized Nmap discovery:

```
nmap -sV <authorized-target>
```

```
nmap --script vuln <authorized-target>
```

Check network connections:

```
ss -tulnp
```

2. Lowe's Wireless Network Intrusion (2003)

Vulnerability Assessment

The Lowe's incident demonstrated that compromising a wireless network can become much more serious when the wireless environment has direct or excessive connectivity to corporate systems.

Key Vulnerabilities

- Insufficient wireless authentication
- Lack of wireless-client isolation
- Poor firewall restrictions
- Inadequate POS network segmentation
- Weak intrusion detection
- Excessive trust between store and corporate networks
- Insufficient centralized access management

Risk

Critical, because compromise of a local wireless network could potentially provide a pathway toward corporate systems and payment information.

Recommendations

1. Deploy WPA2-Enterprise/WPA3-Enterprise.
2. Use **802.1X authentication**.

3. Put guest Wi-Fi in a dedicated VLAN.
4. Completely isolate POS terminals from guest/employee wireless networks.
5. Use firewalls between every security zone.
6. Implement IDS/IPS.
7. Use centralized identity management and access control.
8. Apply least-privilege network access.
9. Monitor unusual connections from store networks.

Linux Commands

View interfaces:

`ip link`

`ip addr`

View routing:

`ip route`

View listening services:

`ss -tulnp`

Authorized service discovery:

`nmap -sV <authorized-IP>`

3. Firesheep and Public Wi-Fi Session Hijacking (2010)

Vulnerability Assessment

Firesheep demonstrated the danger of transmitting authentication cookies over unencrypted HTTP connections. An attacker on the same open wireless network could potentially capture session information and impersonate a user.

Key Vulnerabilities

Open Wi-Fi

Users connected to an untrusted shared network.

HTTP session transmission

If session cookies were transmitted without encryption, they could potentially be exposed.

No HSTS

Without HSTS, browsers could potentially access a site through HTTP instead of enforcing HTTPS.

Weak cookie security

Cookies without appropriate security attributes increased exposure.

Recommendations

- Enforce HTTPS across the entire website.
- Enable **HSTS**.
- Use Secure cookies.
- Use HttpOnly cookies.
- Use appropriate SameSite settings.
- Deploy wireless client isolation.
- Encourage VPN use on untrusted networks.
- Educate users about public Wi-Fi risks.

Linux Commands

Check HTTP response headers:

```
curl -I https://example.com
```

Check whether HTTPS redirects correctly:

```
curl -I http://example.com
```

Check TLS connectivity:

```
openssl s_client -connect example.com:443
```

Check DNS:

```
dig example.com
```

Important: These commands should only be used against systems you are authorized to assess.

4. DarkHotel Attacks Through Hotel Wi-Fi

Vulnerability Assessment

DarkHotel demonstrated that hotel Wi-Fi can be used as an attack platform against high-value visitors. Attackers can abuse weaknesses in captive portals, network management, DNS, software-update mechanisms, and guest isolation.

Key Vulnerabilities

Component	Vulnerability
Guest authentication	Weak authentication
Captive portal	Insufficient security
DNS	Potential manipulation
Network segmentation	Inadequate isolation
Third-party access	Excessive privileges
Software updates	Lack of verification
Monitoring	Insufficient detection

Recommendations

1. Use WPA2/WPA3-Enterprise where practical.
2. Use secure captive portals with HTTPS.
3. Separate guest, employee and administrative networks.
4. Protect DNS using secure DNS infrastructure.
5. Restrict third-party vendor access.
6. Require digitally signed software updates.
7. Verify update signatures before installation.
8. Use endpoint protection and EDR.

9. Monitor privileged hotel systems.

10. Centralize security logs.

Linux Commands

DNS investigation:

dig example.com

dig example.com MX

dig example.com NS

HTTP headers:

curl -I https://example.com

Network connections:

ss -tunap

Route information:

ip route

5. Marriott Wi-Fi Deauthentication Incident (2014)

Vulnerability Assessment

The incident involved the misuse of **IEEE 802.11 deauthentication management frames**. Traditionally, these frames were not adequately protected, allowing unauthorized devices to send forged frames that could disconnect wireless clients.

Security Impact

The main security property affected was:

Availability

Users could be repeatedly disconnected from wireless networks.

Potential consequences include:

- Loss of connectivity
- Service disruption

- Reduced network availability
- Increased operational costs
- Possible interference with legitimate wireless communications

Recommendations

1. Deploy **Protected Management Frames (PMF)**.
2. Use WPA3 where supported.
3. Monitor wireless management-frame anomalies.
4. Deploy WIDS/WIPS.
5. Establish an acceptable-use policy.
6. Detect unauthorized wireless equipment.
7. Investigate repeated client disconnections.
8. Maintain compliance with applicable laws and regulations.

Linux Commands

View wireless interfaces:

```
iw dev
```

View wireless interface information:

```
iwconfig
```

Check network status:

```
nmcli device status
```

Check system logs:

```
journalctl -u NetworkManager
```

Avoid intentionally generating deauthentication traffic against networks. Testing should use an authorized wireless-security lab and appropriate monitoring tools.

6. Fake Wi-Fi Networks at the Republican National Convention (2016)

Vulnerability Assessment

The experiment demonstrated the danger of **fake/evil-twin access points**. Users may trust an SSID simply because its name looks familiar.

Key Vulnerabilities

- SSID trust
- Automatic Wi-Fi reconnection
- Open networks
- Weak captive-portal authentication
- Lack of evil-twin detection
- Poor certificate validation
- Insufficient VPN use
- Low security awareness

Recommendations

1. Disable automatic connection to unknown networks.
2. Use WPA2/WPA3 networks instead of open Wi-Fi whenever possible.
3. Implement enterprise authentication for organizational users.
4. Use VPNs on untrusted networks.
5. Validate HTTPS certificates.
6. Deploy WIDS/WIPS.
7. Monitor for duplicate SSIDs.
8. Provide security-awareness training.
9. Use device certificates for managed devices.

Linux Commands

List visible Wi-Fi networks:

```
nmcli device wifi list
```

View wireless interface:

```
iw dev
```

View NetworkManager connections:

`nmcli connection show`

View DNS configuration:

`resolvectl status`

7. Wi-Fi Attacks Against Anti-Doping Officials (2016)

Vulnerability Assessment

Officials traveling internationally may frequently use hotel, airport and event Wi-Fi. These environments should be treated as **untrusted networks**.

Sensitive information such as credentials and medical information requires strong protection.

Key Vulnerabilities

- Public Wi-Fi exposure
- Credential theft
- Weak authentication
- Lack of MFA
- Lack of device certificates
- Inadequate endpoint protection
- Poor VPN configuration
- Insufficient travel-security procedures

Recommendations

Authentication

Use:

- MFA
- Strong passwords
- Hardware security keys where appropriate
- 802.1X

- Device certificates

Endpoint Security

Devices should use:

- Full-disk encryption
- EDR/anti-malware
- Security patches
- Host firewall
- Screen lock
- Mobile-device management

Network Security

Use:

Hotel Wi-Fi

↓

VPN

↓

Organization Security Gateway

↓

Internal Network

Medical Information

Medical information should have strict access controls, encryption and auditing.

Linux Commands

Check active connections:

`ss -tunap`

Check routing:

`ip route`

Check DNS:

resolvectl status

Check firewall:

sudo ufw status

8. Attempted OPCW Wi-Fi Intrusion (2018)

Vulnerability Assessment

The OPCW incident demonstrated that wireless attacks can be attempted from outside an organization's physical perimeter. Radio-frequency signals may extend beyond physical boundaries, allowing attackers to attempt attacks from nearby locations.

Key Vulnerabilities

- RF exposure outside the perimeter
- Wireless authentication weaknesses
- Improper 802.1X configuration
- Poor EAP certificate validation
- Rogue devices
- Insufficient WIPS
- Physical-security weaknesses
- Weak network-access control

Recommendations

Wireless Authentication

Use:

WPA2/WPA3-Enterprise + 802.1X + RADIUS

For example:

Client



WPA2/WPA3 Enterprise



802.1X



RADIUS



Network Access Control

Certificate Validation

Clients should validate the legitimate authentication server certificate to reduce the risk of connecting to fraudulent infrastructure.

Monitoring

Deploy:

- WIDS/WIPS
- Rogue AP detection
- RF monitoring
- NAC
- Centralized logging

Physical Security

Use:

- CCTV
- Security patrols
- Restricted parking
- Wireless sensor placement
- Detection of suspicious equipment near the perimeter

Linux Commands

Wireless information:

iw dev

iw list

Network configuration:

ip addr

ip route

Check services:

ss -tulnp

9. Australian Airport and In-Flight Evil-Twin Case (2024)

Vulnerability Assessment

An evil-twin attack creates a fraudulent access point that imitates a legitimate Wi-Fi network. Airports and airlines are particularly attractive targets because large numbers of passengers connect to public networks.

Vulnerabilities

Area	Risk
SSID impersonation	Users may connect to fake AP
Automatic connection	Devices may reconnect automatically
Captive portal	Fake login pages
Certificate warnings	Users may ignore warnings
Passenger data	Personal information exposure
Rogue AP detection	Fake AP may remain undetected
Staff response	Delayed removal
User verification	Users may not verify network authenticity

Recommendations

1. Publish the official airport Wi-Fi SSID clearly.
2. Warn users against similarly named networks.
3. Use enterprise authentication for staff.

4. Deploy WIDS/WIPS.
5. Monitor duplicate/rogue SSIDs.
6. Disable automatic connection to open networks on managed devices.
7. Encourage VPN use.
8. Train staff to recognize rogue APs.
9. Use HTTPS everywhere.
10. Provide clear instructions for verifying the official Wi-Fi network.

Linux Commands

List nearby networks:

```
nmcli device wifi list
```

Check saved connections:

```
nmcli connection show
```

Check DNS:

```
resolvectl status
```

Check HTTPS:

```
curl -I https://example.com
```

10. Network Rail Public Wi-Fi Portal Compromise (2024)

Vulnerability Assessment

The reported incident highlights the risk of compromised **administrator accounts** and excessive privileges. Even when the Wi-Fi infrastructure itself is technically secure, a compromised privileged account can allow unauthorized modification of captive-portal content.

Key Vulnerabilities

- Weak privileged-account protection
- Insufficient MFA
- Excessive administrative privileges

- Third-party supplier access
- Poor account monitoring
- Insufficient logging
- Weak change-control procedures
- Inadequate incident response

Risk

High/Critical

A compromised administrator account can potentially allow attackers to modify network services, redirect users, change portal content or affect a large number of users.

Recommendations

Privileged Access Management

Implement:

- PAM
- Least privilege
- Separate administrator accounts
- Just-in-time access
- MFA
- Regular access reviews

Captive Portal

The portal should have:

- HTTPS
- Strong administrator authentication
- Role-based access control
- Secure session management
- Audit logging
- Change tracking

Third-Party Access

Suppliers should receive:

- Minimum required permissions
- Time-limited accounts
- MFA
- Logged administrative sessions
- Regular access reviews

Change Management

All production changes should require:

Change Request

↓

Security Review

↓

Approval

↓

Implementation

↓

Testing

↓

Logging/Audit

Linux Commands

Check logged-in users:

who

Check recent login activity:

last

Check failed authentication attempts:

```
sudo journalctl | grep -i "failed"
```

Check listening services:

```
ss -tulnp
```

Check firewall:

```
sudo ufw status verbose
```

Check system logs:

```
journalctl --since "1 day ago"
```